

5. 인증과 인가

❖ JWT란?

- Claim set 으로 구성된 사용자 정보를 안전하게 전달하기 위한 토큰 형식
- Claim set의 위 변조 여부를 검증하기 위해 서명(Signature) 사용
 - 서명을 이용해 위변조 여부 확인

❖ JWT 구조



예시

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9 • eyJzdWiiOiIxMjMiLCJuYW1lIjoiiIn0 • dBjftJeZ4CVP-mB92K27uhbUJ
JU1p1r_wW1gFWFOEjXk

```
graph LR; H[eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9] --- P[eyJzdWiiOiIxMjMiLCJuYW1lIjoiiIn0] --- S[dBjftJeZ4CVP-mB92K27uhbUJ  
JU1p1r_wW1gFWFOEjXk];
```

Base64 인코딩 (헤더) Base64 인코딩 (페이로드) Base64 인코딩 (서명)

5. 인증과 인가

❖ JWT의 구조

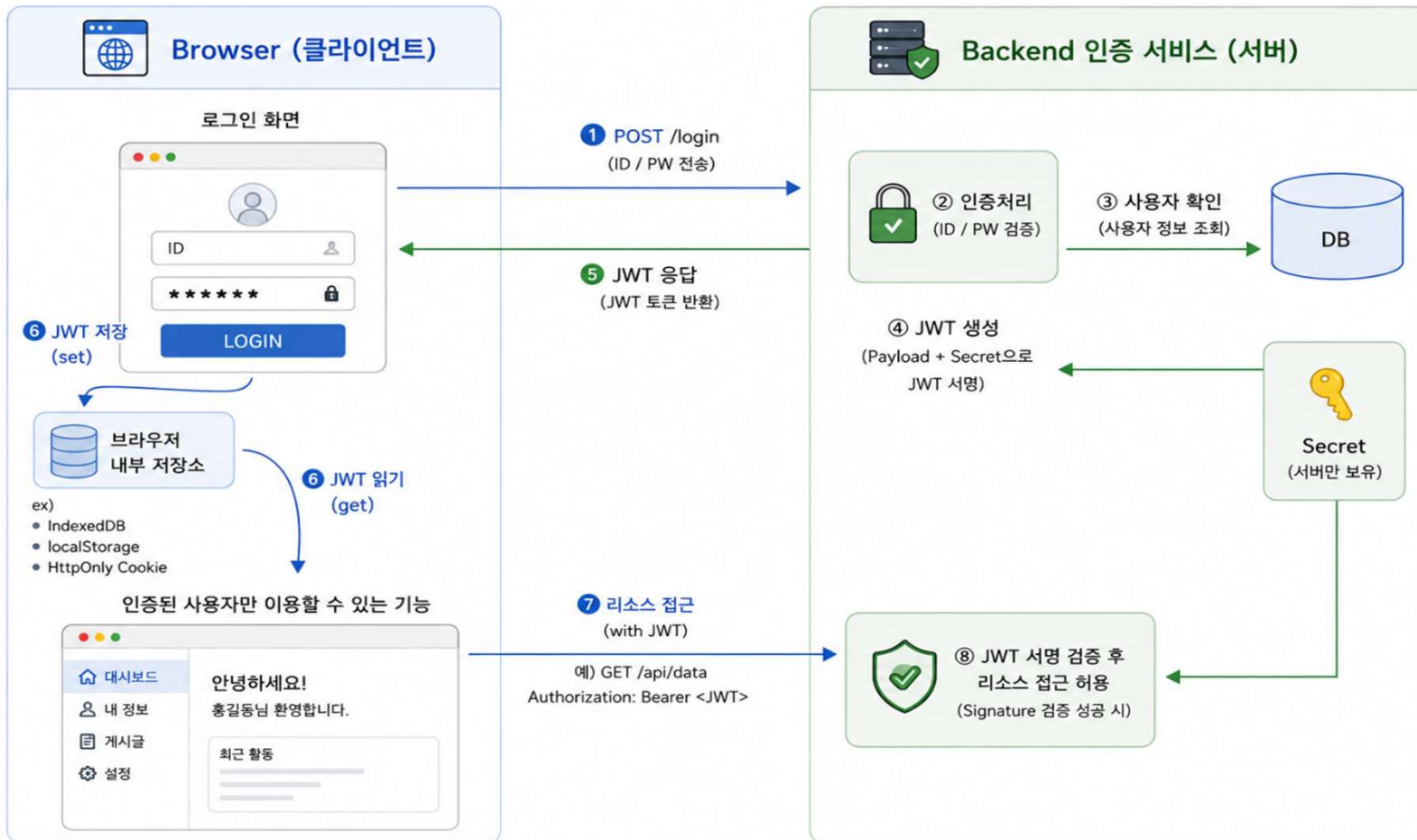


■ 주의 사항

- Header, Payload는 Base64 Encoding 한 것으로 암호화가 아님. 누구나 Decoding 하여 볼 수 있음
- 따라서 Payload에는 사용자의 중요 개인정보(신용카드, 이메일주소 등), 비밀번호는 포함시켜서는 안됨

5. 인증과 인가

❖ JWT를 이용한 인증 흐름



5. 인증과 인가

❖ Access Token + Refresh Token

Access Token만 사용한다면?



- ❌ Access Token은 유효기간을 짧게 설정해야 안전해요.
- ❌ 유효기간이 짧으면 사용자가 자주 로그인해야 해서 불편해요.
- ❌ 유효기간을 길게 설정하면 도난 시 위험이 커져요.

그래서!
두 가지 토큰을
함께 사용해요.

Access Token + Refresh Token을 사용하면!



- ✅ Access Token은 짧게 유지해 도난 피해를 최소화해요.
- ✅ Refresh Token으로 새로운 Access Token을 발급받아 사용자 편의성을 유지해요.
- ✅ Refresh Token은 안전한 곳에 보관하고, 서버에서 관리해요.

[비유 예시]

* AccessToken
: 1회용 놀이기구 티켓

* RefreshToken
: 1회용 놀이기구 티켓을
발급받을수 있는 회원 카드

❖ 동작흐름도

